

TSHELO

Risk Management Framework

Bank of Botswana Regulatory Sandbox Application

Data Sentinels | 31 March 2026 | nbokete@data-sentinels.com | tshelo.com

This Risk Management Framework identifies and assesses all significant risks inherent in and arising from Tshelo's product, business model, and sandbox testing. For each risk, likelihood, impact, a residual rating, and specific safeguards are provided. This framework will be reviewed monthly during the sandbox period and updated as new risks emerge.

1. Risk Assessment Methodology

Tshelo uses a standard likelihood-impact matrix to rate risks. Each risk is assessed before and after the application of safeguards to produce a residual rating.

Rating	Definition	Response
LOW	Unlikely to occur and/or minor impact if it does	Monitor and maintain existing controls. No immediate action required.
MEDIUM	Could occur and/or moderate impact if it does	Apply additional controls. Monitor closely. Escalate if rating increases.
HIGH	Likely to occur and/or severe impact if it does	Immediate action required. Notify Bank of Botswana. Suspend activity if necessary.

2. Risk Register

The following risks are assessed across five categories: Regulatory, Financial, Operational, Technology, and Reputational.

Ref	Risk Description	Likelihood	Impact	Rating	Safeguards
CATEGORY 1 - REGULATORY RISKS					
REG1	Tshelo is reclassified as a payment processor or deposit-taking entity during the sandbox period	LOW	HIGH	MEDIUM	Core architecture ensures zero funds pass through Tshelo. Monthly confirmation to BoB. Immediate suspension protocol if classification changes. Proactive engagement with BoB and NBFIRA throughout.
REG2	Changes to Botswana financial regulation during the sandbox period	LOW	HIGH	LOW	Sandbox participation provides early warning of regulatory changes. Ongoing BoB relationship ensures advance notice.

	affect Tshelo's position				Legal counsel engaged to monitor regulatory developments.
REG3	Non-compliance with Financial Intelligence Act Section 40 general reporting obligation	LOW	MEDIUM	LOW	Internal AML monitoring log maintained throughout. CEO designated as AML compliance contact. Suspicious pattern detection built into platform. Clear escalation path to Financial Intelligence Agency.
REG4	Platform used to facilitate structuring or layering of illicit funds via false contribution records	LOW	HIGH	MEDIUM	Fund growth rate monitoring. Maximum fund size limits (BWP 10,000). OTP identity verification. Full immutable audit trail. No anonymous accounts. Fund scaling only on basis of completed history.

CATEGORY 2 - FINANCIAL RISKS

FIN1	User loses money as a result of Tshelo's operation	LOW	HIGH	LOW	Tshelo holds zero funds at all times. All money remains in users' own licensed mobile money accounts. Financial loss from Tshelo's operation is structurally impossible.
FIN2	Inaccurate contribution record leads to financial dispute between fund members	MEDIUM	MEDIUM	MEDIUM	Full immutable audit trail records all contributions and edits with timestamps. Dispute flagging feature in-app. In-app support and email escalation within 48 hours. PDF export provides independent evidence.
FIN3	Fund organiser misappropriates contributions recorded on platform	LOW	HIGH	LOW	Tshelo does not hold funds. Misappropriation risk sits with mobile money providers, not Tshelo. Full transparency to all fund members deters misuse. Audit trail provides evidence for any dispute.
FIN4	Token payment fraud (user pays for features but does not receive them)	LOW	LOW	LOW	Token purchases processed through established payment gateways. Automatic feature activation on successful payment. Support escalation within 48 hours for any payment issues.

CATEGORY 3 - OPERATIONAL RISKS

OPS1	SMS detection inaccuracy results in wrong contribution amounts being recorded	MEDIUM	MEDIUM	LOW	User confirmation required before any SMS contribution is recorded. No contribution is added automatically. Full audit trail allows correction. Dispute flagging mechanism available to all members.
OPS2	Receipt scanning failure results in expense not being recorded	MEDIUM	LOW	LOW	Manual expense entry available as a fallback at all times. Receipt photo stored even if OCR fails. User can manually enter amount and vendor details.
OPS3	Fund organiser unavailable or unresponsive during active fund	MEDIUM	MEDIUM	MEDIUM	Fund members can view all existing records at any time. PDF export available to any member. Support team can assist with fund access issues. Fund co-organiser feature planned for Version 2.
OPS4	User data not deleted within committed 30-day window on request	LOW	MEDIUM	LOW	Data deletion requests logged immediately on receipt. CEO notified for all deletion requests during sandbox period. Supabase data deletion capability tested before launch.
CATEGORY 4 - TECHNOLOGY RISKS					
TECH1	Platform outage during an active fund	MEDIUM	MEDIUM	LOW	Supabase 99.9% uptime SLA. Automatic database backups every 24 hours. PDF export available before any outage. Users advised to export regularly. Maximum data loss in outage: 24 hours of records.
TECH2	Data breach exposing user names and phone numbers	LOW	HIGH	LOW	All data encrypted at rest (AES-256) and in transit (TLS 1.2+). Row Level Security enforced at database level. OTP authentication. No financial credentials stored. Regular security reviews. Data minimisation policy.
TECH3	Unauthorised access to a fund by a non-member	LOW	MEDIUM	LOW	Closed-loop invite-only design. Unique access codes per fund. OTP verification required for all accounts. RLS policies prevent cross-user data access at database level.

TECH4	SMS permission revoked by user mid-fund, breaking detection	MEDIUM	LOW	LOW	Manual contribution entry always available as fallback. Users reminded at onboarding that SMS permission is optional. App functions fully without SMS permission.
TECH5	Mobile app removed from app store during sandbox period	LOW	HIGH	MEDIUM	App store compliance review completed before launch. Content and functionality aligned with store policies. Direct APK distribution as backup for Android users if required. BoB notified immediately if this occurs.
CATEGORY 5 - REPUTATIONAL RISKS					
REP1	Negative media coverage linking Tshelo to a financial fraud or scam	LOW	HIGH	LOW	Proactive regulatory engagement with BoB and NBFIRA provides credibility. Sandbox participation demonstrates legitimacy. Fraud detection measures in place. CEO designated as media contact. Rapid response protocol prepared.
REP2	Community distrust due to data privacy concerns	MEDIUM	MEDIUM	LOW	Clear and plain-language privacy disclosure at onboarding. Data minimisation. No financial data stored. Deletion rights prominently communicated. Compliance with Botswana Data Protection Act principles.
REP3	Sandbox test failure damages Data Sentinels' credibility for future product launches	LOW	MEDIUM	LOW	Conservative test scope and user limits reduce failure risk. Comprehensive preparation of all frameworks before launch. Exit plan prepared. BoB relationship maintained regardless of test outcome.

3. Risk Governance and Oversight

3.1 Risk Ownership

Role	Responsibilities
CEO (Nono Bokete)	Overall accountability for this framework. AML compliance contact. Escalation point for all HIGH-rated risks. Liaison with Bank of Botswana.

Engineering Lead	Ownership of all TECH risks. Platform monitoring. Security controls. Data breach response.
Support Team	First line for OPS risks. Complaints handling. Dispute resolution. User communication.
Bank of Botswana	Regulatory oversight. Notified immediately of any HIGH-rated risk materialising. Receives monthly risk update in progress reports.

3.2 Risk Review Schedule

- Monthly: Full risk register reviewed and updated. Changes reported to BoB in monthly progress report.
- Immediate: Any risk that escalates to HIGH rating triggers immediate notification to BoB within 48 hours.
- Quarterly: Full framework review with CEO sign-off.
- At test close: Final risk assessment included in the sandbox final report.

3.3 Escalation Protocol

If any risk materialises or escalates to a HIGH rating, the following steps will be taken:

- Step 1: CEO notified immediately by the team member who identifies the risk
- Step 2: Incident logged with date, nature, affected users, and immediate actions taken
- Step 3: Bank of Botswana notified within 48 hours via email to the sandbox team
- Step 4: Affected users notified within 24 hours where their data or funds are impacted
- Step 5: Corrective action implemented and documented within 5 business days
- Step 6: Post-incident review completed and findings included in next monthly report

4. Inherent Safeguards in Tshelo's Business Model

Tshelo's core architecture provides inherent risk mitigation that distinguishes it from higher-risk financial service providers:

Safeguard	How It Mitigates Risk
Zero fund custody	Tshelo never holds funds. This eliminates custody risk, misappropriation risk, and liquidity risk entirely. Users' money is always in their own licensed mobile money accounts.
Closed-loop design	Funds are invite-only and private. This eliminates public fraud risk (such as false fundraising campaigns) and limits the attack surface for misuse.
Immutable audit trail	Every contribution, expense, and edit is permanently recorded with a timestamp and the identity of the person who made the change. Nothing can be deleted or hidden.

OTP identity verification	All accounts are verified via a one-time password sent to the user's registered mobile number. No anonymous accounts are permitted.
Fund size limits and scaling	Initial funds are capped at BWP 10,000. Limits increase only on the basis of completed fund history and community ratings, preventing large-scale misuse from the outset.
KYC delegated to mobile money providers	All contributors are already verified by their mobile money provider (Orange Money, MyZaka, Smega). Tshelo's OTP layer adds a further identity check without duplicating the full KYC process.